WALKER PRESS

CompTIA Security+ SY0-701

Practice Exam 3 of 5

90 Questions | 90 Minutes | Passing score 750 on a scale of 100–900

• This practice exam mirrors the format of the CompTIA Security+ SY0-701 certification exam: a maximum of 90 questions in 90 minutes.
• CompTIA reports the passing score as 750 on a scale of 100 to 900. That scale is CompTIA's own and is not a percentage of correct answers, so this document does not print a pass mark of its own. Use the Answer Key to find the objectives that need another evening.
• Questions are weighted by domain as on the real exam: General Security Concepts 12%, Threats, Vulnerabilities, and Mitigations 22%, Security Architecture 18%, Security Operations 28%, Security Program Management and Oversight 20%.
• Question types include Multiple Choice, Select Two/Three and Matching. For Matching questions, pair each item with the best description.
• The Answer Key with a full explanation for every question is at the end of this document.

www.walker-press.com

Questions

Question 1 [Multiple Choice]

Which of the following is a common feature of endpoint detection and response (EDR) solutions?

- **A.** Automated full-disk backup and imaging
- **B.** DNS resolution logging as the agent's only telemetry
- **C.** Web application request filtering at the network edge
- **D.** Real-time threat containment and investigation

Question 2 [Multiple Choice]

Which of the following is NOT correct about security automation?

- **A.** Automation can create tickets and escalate alerts.
- **B.** Security automation always requires both AI and ML.
- **C.** Automation can help enforce baselines and standard configurations.
- **D.** Automation can enable or disable services and access.

Question 3 [Multiple Choice]

Yusuf has been asked to experiment with different hardware to create a controller for a new device on the factory floor. He needs a credit-card-sized motherboard that has a microcontroller instead of a microprocessor. Which would be the best solution?

- **A.** Raspberry Pi
- **B.** Arduino
- **C.** FPGA
- **D.** SoC

Question 4 [Multiple Choice]

Fill in the blank: A _____ is a file that contains known patterns used to identify malicious code.

- **A.** Signature
- **B.** Heuristic analysis
- **C.** Behavioral analysis
- **D.** Anomaly detection

Question 5 [Multiple Choice]

Fill in the blank: A _____ vulnerability is one that has been publicly disclosed but not yet patched by the vendor.

- **A.** Social engineering
- **B.** Malware
- **C.** Zero-day
- **D.** Phishing

Question 6 [Multiple Choice]

Fill in the blank: _____ is a process in which legitimate users are denied access due to overwhelming traffic.

- **A.** Man-in-the-middle
- **B.** Phishing
- **C.** Denial-of-service (DoS)
- **D.** Buffer overflow

Question 7 [Multiple Choice]

A company hires a firm to test its internet-facing systems. The testers receive only the company name and are told to discover the target systems themselves; no network diagrams, credentials, or source code are provided. Which type of penetration test is this?

A. Integrated
B. Known environment
C. Unknown environment
D. Partially known environment

Question 8 [Multiple Choice]

A user reports that files are being encrypted one by one and renamed with a strange extension. What type of malware is likely involved?

A. Worm
B. Keylogger
C. Rootkit
D. Ransomware

Question 9 [Matching]

Match each incident response role with its responsibility.

Items	Descriptions
1. Incident commander	**A.** Has overall authority during a security event
2. Communications coordinator	**B.** Manages internal and external reporting
3. Legal advisor	**C.** Coordinates forensic containment and eradication
4. Technical lead	**D.** Ensures regulatory and legal compliance

Question 10 [Multiple Choice]

Fill in the blank: The process of granting, modifying, or revoking access to systems or resources is called _____.

A. Forensic imaging
B. Threat hunting
C. Playbook execution
D. Provisioning

Question 11 [Multiple Choice]

Which WPS connection method is most susceptible to a remote brute-force attack?

A. PIN
B. Push-button
C. Click-to-send
D. NXC

Question 12 [Multiple Choice]

Lyam is researching scripting. Which of the following is NOT correct about scripting?

A. Scripting can help enforce standard infrastructure configurations and guard rails.
B. Scripting should not be used for automation.
C. Scripting can automate user-provisioning tasks.
D. Scripting can integrate security tools through APIs.

Question 13 [Multiple Choice]

Which of the following logs contains data that describes information about other data?

A. Endpoint log
B. Application log
C. Metadata log
D. Network log

Question 14 [Multiple Choice]

Which policy outlines how applications should be developed?

A. SCAP
B. SARC
C. SDLC
D. SORA

Question 15 [Multiple Choice]

What does a watering hole attack attempt to exploit?

A. Weak Wi-Fi encryption
B. Overused passwords
C. USB device insertion
D. Frequently visited websites

Question 16 [Multiple Choice]

A hospital is negotiating a contract with a cloud provider that will store patient records. The compliance team insists that the contract allow the hospital, or an assessor acting for it, to inspect the provider's security controls and relevant records during the relationship. Which contractual element satisfies this requirement?

A. A non-disclosure agreement
B. A statement of rules of engagement
C. A right-to-audit clause
D. A conflict-of-interest disclosure

Question 17 [Multiple Choice]

A system is configured to deny all network traffic unless explicitly allowed. What security principle does this demonstrate?

A. Default deny
B. Role-based access
C. Principle of least privilege
D. Zero trust

Question 18 [Matching]

Match each monitoring method to its description.

Items	Descriptions
1. Agent-based monitoring	**A.** Compares observed artifacts or activity against known malicious signatures
2. Agentless monitoring	**B.** Uses remote access protocols without client installation
3. Signature-based detection	**C.** Analyzes behavior to identify unknown threats
4. Heuristic detection	**D.** Requires local software installation

Question 19 [Multiple Choice]

A company is negotiating a long-term relationship with an IT services vendor. They want one overarching contract that defines the general terms and conditions of the relationship, with each future project to be defined in its own statement of work. Which agreement type should they use?

A. MSA
B. BPA
C. SLA
D. MOU

Question 20 [Multiple Choice]

Which of the following terms describes a process where an attacker intercepts and alters communications between two parties without their knowledge?

A. Man-in-the-middle
B. Evil twin
C. Session replay
D. DNS tunneling

Question 21 [Matching]

Match each framework or law with its focus.

Items	Descriptions
1. HIPAA	**A.** Personal data protection for EU residents
2. NIST CSF	**B.** Payment security standards
3. PCI DSS	**C.** Health information privacy
4. GDPR	**D.** Cybersecurity risk management

Question 22 [Matching]

Match each compliance term with its description.

Items	Descriptions
1. Policy	**A.** Step-by-step operational steps
2. Standard	**B.** Recommended but not mandatory
3. Guideline	**C.** Detailed technical specification
4. Procedure	**D.** Broad security requirement

Question 23 [Multiple Choice]

A defense contractor requires that the system storing its most sensitive design files have no physical or wireless connection to any other network. Which architecture approach satisfies this requirement?

A. Software-defined networking (SDN)
B. Air-gapped isolation
C. Containerization
D. Logical segmentation

Question 24 [Multiple Choice]

Which security operations task is an appropriate use case for automation and scripting?

A. Automatically create and route a ticket when a vulnerability scanner detects a critical finding.
B. Automatically grant every newly provisioned user administrator privileges.
C. Automatically disable endpoint logging on every host when storage utilization on the log server reaches 80%.
D. Automatically delete unreviewed security alerts after 24 hours.

Question 25 [Matching]

Match each cryptographic technique to what it does.

Items	Descriptions
1. Hashing	**A.** Replaces sensitive data with a non-sensitive substitute stored in a secure vault
2. Salting	**B.** Distributes trust across a chain of certificate authorities
3. Steganography	**C.** Scrambles an entire disk volume to protect data at rest
4. Tokenization	**D.** Applies the sender's private key to prove origin and integrity
5. Digital signature	**E.** Conceals the existence of a message by hiding it inside another file
	F. Produces a fixed-length, one-way digest to verify integrity
	G. Adds random data to a password before hashing to defeat precomputed tables

Question 26 [Multiple Choice]

Fill in the blank: The _____ protocol is used to request certificate status information in real time.

A. RADIUS
B. OCSP
C. LDAP
D. CRL

Question 27 [Multiple Choice]

Which of the following security controls would be most effective against social engineering attacks?

- **A.** NAT
- **B.** Host-based firewall
- **C.** User training and awareness
- **D.** Data loss prevention (DLP)

Question 28 [Matching]

An identity and access management team is reviewing the controls it applies to accounts across the enterprise. Match each identity and access management practice to the situation in which it is being applied.

Items	Descriptions
1. Rule-based access control	**A.** Contractor accounts are prevented from signing in between 8 p.m. and 6 a.m.
2. Time-of-day restriction	**B.** A firewall access list applies the same permit and deny conditions to every connection attempt, whoever initiates it
3. Attestation	**C.** Managers formally certify each quarter that the people on their team still require the access they hold
4. Identity proofing	**D.** Access is recalculated at every request from the requester's department, device posture, and clearance
	E. Every user receives only the permissions required to perform their job duties, and nothing more
	F. A new hire must present a government-issued ID and answer knowledge-based verification questions before an account is created

Question 29 [Multiple Choice]

Which of the following best describes a vulnerability scan?

- **A.** An automated assessment that identifies known weaknesses in systems or applications
- **B.** A guarantee that every weakness it reports is exploitable
- **C.** A one-time activity that removes the need to rescan after remediation
- **D.** An audit that evaluates only an organization's security procedures and processes

Question 30 [Matching]

Match each identity management term to its meaning.

Items	Descriptions
1. Federation	**A.** Using multiple verification methods
2. SSO	**B.** Linking identities across organizations
3. MFA	**C.** Centralized authentication across services
4. Deprovisioning	**D.** Automatically removing access when no longer needed

Question 31 [Multiple Choice]

What control would best limit network-based lateral movement between workloads after a user account is compromised?

- **A.** Application whitelisting
- **B.** Disabling file sharing
- **C.** VLAN hopping
- **D.** Microsegmentation

Question 32 [Multiple Choice]

Which of the following is NOT correct about guardrails?

- **A.** Guardrails leverage cloud APIs and automation.
- **B.** Guardrails add friction to slow down the development process.
- **C.** Guardrails can automatically remediate issues.
- **D.** Guardrails constantly watch cloud deployments.

Question 33 [Matching]

Match each compliance-related document with its purpose.

Items	Descriptions
1. SLA	**A.** Defines expected performance and services
2. NDA	**B.** High-level understanding between two parties
3. AUP	**C.** Outlines acceptable behavior when using systems
4. MOU	**D.** Legal protection of shared confidential data

Question 34 [Select Two]

In Zero Trust Architecture, decision-making responsibilities live in the control plane. Which TWO of the following are control-plane components? (Select TWO.)

- **A.** Implicit trust zone
- **B.** Subject/System
- **C.** Policy Engine
- **D.** Policy Administrator
- **E.** Policy Enforcement Point

Question 35 [Multiple Choice]

Fill in the blank: The purpose of _____ is to group and correlate logs from multiple devices into one view.

- **A.** Threat hunting driven by hypotheses about adversary behavior
- **B.** SIEM (Security Information and Event Management)
- **C.** Incident triage against a documented severity matrix
- **D.** Log analysis performed on a single host's local records

Question 36 [Matching]

Match each risk term with its definition.

Items	Descriptions
1. Risk appetite	**A.** Level of risk remaining after controls
2. Residual risk	**B.** General level of risk an organization is willing to accept
3. Risk tolerance	**C.** Willingness to accept deviations within limits
4. Inherent risk	**D.** Total risk without controls applied

Question 37 [Multiple Choice]

An attacker gains admin access by chaining multiple low-severity bugs. What is this technique called?

- **A.** Exploit chaining
- **B.** Zero-day escalation
- **C.** Privilege elevation
- **D.** Vulnerability stacking

Question 38 [Multiple Choice]

Which of the following would BEST help ensure system configurations are consistent across all servers?

- **A.** Cloud monitoring
- **B.** Virtual patching
- **C.** Configuration baselines
- **D.** Asset tagging

Question 39 [Multiple Choice]

What attack exploits repeated attempts to guess a password through rapid automation?

- **A.** DNS spoofing
- **B.** Brute-force attack
- **C.** Man-in-the-middle
- **D.** Clickjacking

Question 40 [Multiple Choice]

What is the key function of a UTM (Unified Threat Management) appliance?

- **A.** To manage multifactor authentication enrollment and tokens
- **B.** To combine multiple security functions in one device
- **C.** To replace an organization's cloud-delivered security services
- **D.** To store and protect the organization's encryption keys

Question 41 [Multiple Choice]

Ansgar is studying how digital certificates can be used. Which of the following is NOT a use of a digital certificate?

- **A.** To encrypt channels to provide secure communication between clients and servers
- **B.** To verify the identity of clients and servers on the web
- **C.** To encrypt messages for secure email communications
- **D.** To guarantee that a certificate authority will never be compromised

Question 42 [Multiple Choice]

A risk analyst is performing a quantitative analysis of a warehouse management system valued at $200,000. A fire in the server room is estimated to destroy 25 percent of the asset's value, and such a fire is expected to occur once every two years. What is the annualized loss expectancy (ALE)?

A. $100,000
B. $50,000
C. $12,500
D. $25,000

Question 43 [Multiple Choice]

Which of the following best supports continuous monitoring in a SOC environment?

A. Email gateways
B. Packet sniffers
C. Data backup tools
D. SIEM platforms

Question 44 [Multiple Choice]

During a change advisory board review, a member asks what will let the team quickly return a production system to its previous working state if a scheduled upgrade fails. Which element of the change process are they describing?

A. Maintenance window
B. Backout plan
C. Impact analysis
D. Standard operating procedure

Question 45 [Multiple Choice]

Fill in the blank: The _____ value in CVSS scoring reflects the ease with which a vulnerability can be exploited.

A. Buffer overflow
B. SQL injection
C. Social engineering
D. Exploitability

Question 46 [Multiple Choice]

Fill in the blank: The _____ phase of incident response focuses on determining if a security event has occurred.

A. Vulnerability scanning
B. EDR containment
C. Identification
D. Log analysis

Question 47 [Multiple Choice]

Which type of hypervisor runs directly on a computer's hardware?

A. Type II
B. Type IV
C. Type I
D. Type III

Question 48 [Multiple Choice]

A technician notices that multiple systems have stopped receiving updates after a recent configuration change. What type of error could this represent?

A. Policy violation
B. Rootkit
C. Misconfiguration
D. Session hijacking

Question 49 [Multiple Choice]

Which of the following tools would best support investigation of a lateral movement during a breach?

A. Network traffic analyzer
B. Secure email gateway
C. Backup client
D. Patch manager

Question 50 [Multiple Choice]

Which method reduces the attack surface by disabling unused ports and services?

A. Load balancing
B. Sandboxing
C. Whitelisting
D. System hardening

Question 51 [Multiple Choice]

Which deception technology is a fake credential, API key, or database record planted so that any attempt to use it triggers an alert and reveals unauthorized activity?

A. Honeyfile
B. Honeypot
C. Honeytoken
D. Honeynet

Question 52 [Multiple Choice]

What is the purpose of a self-signed certificate?

A. To sign authoritative DNS responses for a public zone
B. To encrypt and authenticate internal communications
C. To bypass HTTPS certificate warnings shown by browsers
D. To enable geofencing for location-based access

Question 53 [Multiple Choice]

A company encrypts data at rest and in transit. Which CIA principle does this MOST support?

A. Availability
B. Confidentiality
C. Integrity
D. Accountability

Question 54 [Matching]

Match each social engineering attack to its technique.

Items	Descriptions
1. Tailgating	**A.** Lying about identity to obtain data
2. Pretexting	**B.** Leaving infected USB drives
3. Vishing	**C.** Following someone into a secured area
4. Baiting	**D.** Fake phone call from "technical support"

Question 55 [Multiple Choice]

A company uses a tool to automatically block known malicious IP addresses. What kind of control is this?

- **A.** Compensating
- **B.** Corrective
- **C.** Preventive
- **D.** Detective

Question 56 [Multiple Choice]

What is the function of a bastion host in a secure network design?

- **A.** Provides controlled access to a private network from an external location
- **B.** Hosts a DMZ for client VPN connections
- **C.** Distributes inbound client sessions evenly across a pool of backend servers
- **D.** Monitors container orchestration in cloud

Question 57 [Multiple Choice]

Ichika wants to examine aggregated network-flow metadata, including connection timing, frequency, and destinations, to identify devices making periodic outbound connections to a C&C server. Which type of analysis is most appropriate?

- **A.** Probe analysis
- **B.** Port analysis
- **C.** Traffic analysis
- **D.** Packet analysis

Question 58 [Multiple Choice]

What is the purpose of a business continuity plan (BCP)?

- **A.** Enforce perimeter firewall rules across all network edges
- **B.** Detect insider threats through continuous behavior monitoring
- **C.** Automatically restore backup data after a system outage
- **D.** Maintain operations during and after disruptions

Question 59 [Multiple Choice]

Which of the following BEST supports a zero trust strategy?

- **A.** Per-request policy evaluation
- **B.** Always-on VPN
- **C.** Role-based access without reauth
- **D.** Local-only authentication

Question 60 [Multiple Choice]

Which of the following is NOT true about threat intelligence?

A. Threat intelligence is data that is collected, processed, and analyzed to understand a threat actor's motives, targets, and attack behaviors
B. Threat intelligence enables organizations to make faster, more informed data-based security decisions
C. Threat intelligence is a form of active testing that requires exploiting target systems
D. Threat intelligence changes behavior from being reactive to proactive

Question 61 [Multiple Choice]

What is the difference between a vulnerability and a threat?

A. A threat is an unpatched system; a vulnerability is an attacker
B. A vulnerability is an exploitable weakness; a threat is a potential cause of harm
C. A vulnerability is detected after a threat; a threat is the result
D. They are interchangeable terms

Question 62 [Select Two]

An intelligence briefing describes an adversary that maintains long-term, stealthy access to critical infrastructure. Which TWO attributes most strongly characterize a nation-state threat actor? (Select TWO.)

A. Reliance solely on pre-built tools they do not understand
B. Access to custom malware and zero-day exploits
C. Consistently noisy, easily detected attacks
D. Very high resources and funding
E. A primary motivation of petty vandalism for fun

Question 63 [Multiple Choice]

Zuri is on vacation and visits a local coffee shop to enjoy a beverage and check her email through the free Wi-Fi. When she first connects, a screen appears asking her to agree to an acceptable use policy (AUP) before continuing. What type of AP portal has she encountered?

A. Rogue portal
B. Approval portal
C. Captive portal
D. Limited portal

Question 64 [Multiple Choice]

Which of the following is considered an administrative control?

A. Security awareness training
B. Motion detector
C. SIEM alerting
D. Patch management scripts

Question 65 [Multiple Choice]

Which of the following is an organizational change rather than a procedural activity carried out during change management?

A. Change allow lists/deny lists
B. Execute backout plan or maintenance window
C. Implement impact analysis or test results
D. Change in ownership or stakeholders

Question 66 [Matching]

Match each attack with its example.

Items	Descriptions
1. Vishing	**A.** An email appearing to come from the CEO asks accounts payable to make an urgent wire transfer.
2. Smishing	**B.** An automated phone call directs a user to call a fraudulent bank number and provide account credentials.
3. Pretexting	**C.** An SMS says, "Your bank account has been locked; click here to unlock it."
4. Business email compromise	**D.** A person creates a detailed false identity and backstory as an external auditor to obtain confidential records.

Question 67 [Multiple Choice]

Which of the following is NOT true about BEC?

- **A.** It is decreasing in popularity among threat actors
- **B.** It takes advantage of electronically making payments or transferring funds
- **C.** It takes advantage of the size and complexity of large enterprises
- **D.** It is not limited to businesses

Question 68 [Multiple Choice]

What does containerization do?

- **A.** It splits operating system functions only on specific brands of mobile devices.
- **B.** It slows down a mobile device to half speed.
- **C.** It places all keys in a special vault.
- **D.** It separates personal data from corporate data.

Question 69 [Matching]

Match each security control example to its category.

Items	Descriptions
1. Camera system	**A.** Managerial
2. Security policy	**B.** Technical
3. Anti-malware software	**C.** Operational
4. Incident response training	**D.** Physical

Question 70 [Multiple Choice]

A user logs in using a username, password, and fingerprint scan. This is an example of:

- **A.** Two-step verification
- **B.** Multifactor authentication
- **C.** Federation
- **D.** Single sign-on

Question 71 [Multiple Choice]

An attacker modifies DNS responses to redirect users to a malicious site. What type of attack is this?

A. VLAN hopping
B. Session hijacking
C. DNS spoofing
D. Password spraying

Question 72 [Multiple Choice]

What is a risk of using outdated cryptographic algorithms in secure communications?

A. Exposure to brute-force or known attacks
B. Failure of biometric devices
C. Lower email deliverability
D. Increase in memory usage

Question 73 [Multiple Choice]

Fill in the blank: The process of _____ involves evaluating and ranking risks based on likelihood and impact.

A. Security awareness training
B. Risk assessment
C. Third-party audit
D. Policy review

Question 74 [Multiple Choice]

Which platform uses playbooks to orchestrate multiple security tools and automate response workflows such as ticket creation, escalation, and disabling access?

A. SOAR
B. Vulnerability scanner
C. DLP
D. SIEM

Question 75 [Multiple Choice]

Fill in the blank: _____ is a proactive process of seeking threats that have evaded traditional defenses.

A. Threat hunting
B. Log analysis
C. Vulnerability scanning
D. Penetration testing

Question 76 [Matching]

Match each authentication protocol with its key characteristic.

Items	Descriptions
1. Kerberos	**A.** Ticket-granting protocol for internal SSO
2. RADIUS	**B.** Federated identity for cloud-based applications
3. LDAP	**C.** Directory access protocol used for user lookups
4. SAML	**D.** Used for centralized authentication over UDP

Question 77 [Multiple Choice]

Which network appliance category is specifically intended to combine firewall, antivirus, intrusion detection or prevention, and content filtering in a single platform?

A. NGFW
B. NAT
C. WAF
D. UTM

Question 78 [Multiple Choice]

Which of the following is NOT correct about a secure cookie?

A. It protects the web browser itself from malware and other browser attacks.
B. The Secure attribute directs the browser to send the cookie only over a secure connection.
C. When HTTPS is used, TLS encrypts the HTTP request containing the cookie header.
D. It reduces the risk that an interceptor can read the cookie while it is in transit.

Question 79 [Multiple Choice]

Fill in the blank: The _____ identifies the point in time to which data must be restored after a disruption.

A. RPO (Recovery Point Objective)
B. SLA (Service Level Agreement)
C. MTBF (Mean Time Between Failures)
D. RTO (Recovery Time Objective)

Question 80 [Multiple Choice]

Fill in the blank: The _____ phase of incident response includes restoring operations to normal and confirming systems are functioning properly.

A. MTBF (Mean Time Between Failures)
B. RPO (Recovery Point Objective)
C. MTTR (Mean Time To Repair)
D. Recovery

Question 81 [Multiple Choice]

An application verifies that an object reference is not NULL. Before the application uses the reference, another process changes it to NULL, causing a crash when it is dereferenced. Which race condition does this illustrate?

A. Time-of-check/time-of-use (TOCTOU) race condition
B. Conflict-based resource race condition
C. Thread-scheduling execution race condition in the kernel scheduler
D. Value-comparison memory race condition

Question 82 [Multiple Choice]

Ahmet is reviewing the resource and design considerations that make it challenging to secure a new embedded system. Which of the following is a security control rather than one of these considerations?

A. Authentication
B. Compute
C. Power
D. Cost

Question 83 [Multiple Choice]

Which type of attack involves injecting malicious code into a dynamic SQL statement?

- **A.** SQL injection
- **B.** Directory traversal
- **C.** XSS
- **D.** XML external entity

Question 84 [Multiple Choice]

After completing an internal review of its security controls, a software vendor's executives sign a formal statement, provided to enterprise customers, declaring that the controls described in its security documentation are implemented and operating as stated. Which term describes this signed declaration?

- **A.** Attestation
- **B.** Regulatory examination
- **C.** Independent third-party audit
- **D.** Self-assessment

Question 85 [Multiple Choice]

Which of the following BEST mitigates a cross-site request forgery (CSRF) attack?

- **A.** Token-based session validation
- **B.** DNS filtering
- **C.** Data encryption
- **D.** Strong passwords

Question 86 [Multiple Choice]

Which of the following is NOT an element that should be part of a BCP?

- **A.** Documented recovery procedures
- **B.** Simplicity as a mandatory planning objective
- **C.** Defined recovery roles and responsibilities
- **D.** Prioritized critical business functions

Question 87 [Multiple Choice]

Fill in the blank: The process of converting plaintext into ciphertext using a public algorithm and a key is called _____.

- **A.** Hashing
- **B.** Encryption
- **C.** Obfuscation
- **D.** Tokenization

Question 88 [Matching]

Match each access control type to its method.

Items	Descriptions
1. MAC	**A.** Based on rules and attributes
2. RBAC	**B.** Based on user-defined permissions
3. ABAC	**C.** Based on roles and job functions
4. DAC	**D.** Based on labels and classification levels

Question 89 [Matching]

Match each incident response role to its responsibility.

Items	Descriptions
1. Legal advisor	**A.** Leads response activities and decision-making
2. Technical lead	**B.** Directs technical remediation and containment
3. Communications officer	**C.** Ensures chain of custody and compliance
4. Incident commander	**D.** Handles external and internal messaging

Question 90 [Multiple Choice]

Under a default-deny firewall policy, which standard rule action permits traffic that matches an explicitly configured exception?

A. Force Deny
B. Allow
C. Bypass
D. Force Allow

Answer Key

Each answer is followed by the reasoning behind it, including why the other options fall short.

Q1: D

D (Real-time threat containment and investigation) is correct: EDR agents continuously record process, file and network activity on the endpoint, flag suspicious behaviour, and let an analyst isolate the host, kill processes and reconstruct the timeline. B (DNS resolution logging as the agent's only telemetry) is incorrect because DNS activity is one narrow signal an EDR may collect, not the whole of what the product does. C (Web application request filtering at the network edge) is incorrect because inspecting HTTP requests to protect a web application is the role of a WAF, not of an endpoint agent. A (Automated full-disk backup and imaging) is incorrect because scheduled imaging belongs to backup software and serves recovery, not detection.

Q2: B

B. 'Security automation always requires both AI and ML' is the statement that is NOT correct. Automation is typically built from scripts, playbooks, and API integrations; AI and ML can enhance it, but neither is required. A. is a true statement — ticket creation and alert escalation are standard automation use cases. C. is true — enforcing secure baselines and standard infrastructure configurations is a recognized benefit of automation. D. is true — enabling and disabling services and access is a common automation use case in provisioning and incident response.

Q3: B

D. SoC is incorrect. A System on a Chip integrates a full processor, memory, and peripherals on one die - it is a complete computer subsystem, not the minimal microcontroller board best suited to a simple factory-floor controller. A. Raspberry Pi is incorrect. The Raspberry Pi runs a full microprocessor and a general-purpose operating system; it is more capable (and more complex) than needed to drive a single device controller. B. Arduino is correct. Arduino boards are small, low-cost microcontroller boards designed exactly for embedded control tasks like reading sensors and driving actuators on a factory floor, with no operating system to manage. C. FPGA is incorrect. A Field-Programmable Gate Array is reconfigurable logic hardware programmed at the gate level - powerful for custom digital circuits but far more complex than required for a straightforward device controller.

Q4: A

B. Heuristic analysis is incorrect. Heuristic analysis identifies unknown threats by examining behavioral characteristics and code patterns — it is a detection method, not a file of known patterns. A. Signature is correct. A signature file contains known patterns (byte sequences, hash values, or code strings) extracted from previously identified malware. Antivirus engines compare scanned files against these signatures to detect known threats quickly and accurately. C. Behavioral analysis is incorrect. Behavioral analysis monitors how programs execute at runtime to detect suspicious activity — it does not rely on pre-stored pattern files. D. Anomaly detection is incorrect. Anomaly detection flags deviations from an established baseline — it is not a file of known malicious patterns.

Q5: C

A. Social engineering is incorrect. Social engineering is a category of attack exploiting human behavior, not a type of software vulnerability classification. B. Malware is incorrect. Malware is a general term for malicious software — it is not a vulnerability descriptor. D. Phishing is incorrect. Phishing is a social engineering attack method — not a term describing the patch status of a disclosed vulnerability. C. Zero-day is correct. A zero-day vulnerability is one that has been publicly disclosed but for which no vendor patch yet exists — named because defenders have 'zero days' to apply a fix. Attackers may exploit it while the vendor works on a patch, creating a critical window of exposure.

Q6: C

B. Phishing is incorrect. Phishing is a social engineering attack that tricks users via fraudulent emails or websites — it does not involve overwhelming a target with network traffic. D. Buffer overflow is incorrect. A buffer overflow occurs when a program writes more data to a memory buffer than it can hold, potentially enabling code execution — it is a software vulnerability, not a traffic-based availability attack. A. Man-in-the-middle is incorrect. A MITM attack intercepts communication between two parties to eavesdrop or alter data — it does not flood a target to deny service. C. Denial-of-service (DoS) is correct. A DoS attack floods a target system, server, or network with traffic or requests, exhausting its processing capacity or bandwidth and making it unavailable to legitimate users. When coordinated from many compromised hosts simultaneously, it becomes a Distributed DoS (DDoS), significantly amplifying the attack volume.

Q7: C

C is correct (Unknown environment): in an unknown environment test, sometimes called black box, the testers start with no internal knowledge and must discover the attack surface through reconnaissance, which most closely simulates an external attacker. D is incorrect (Partially known environment) because a partially known test gives testers some information, such as an IP range, an architecture overview, or a standard user account, to focus the effort. B is incorrect (Known environment) because a known environment test provides full documentation, credentials, and often source code, so the engagement is about depth rather than discovery. A is incorrect (Integrated) because integrated testing describes offensive and defensive teams working together during the exercise; it concerns who participates, not how much information the testers receive.

Q8: D

B. Keylogger is incorrect. A keylogger records keystrokes to steal credentials; it does not encrypt or rename a victim's files. A. Worm is incorrect. A worm self-propagates across systems; spreading is its defining behavior, not encrypting files and changing their extensions. D. Ransomware is correct. Systematically encrypting files one by one and appending an unusual extension is the classic signature of ransomware, which locks the victim's data and then demands payment for the decryption key. C. Rootkit is incorrect. A rootkit hides its presence and maintains privileged access; it conceals activity rather than openly encrypting and renaming files.

Q9: 1 = A; 2 = B; 3 = D; 4 = C

The Incident commander pairs with "Has overall authority during a security event" since this role owns strategic decisions and coordinates all other responders. The Communications coordinator pairs with "Manages internal and external reporting," handling messaging to employees, customers, regulators, and the press so that technical teams can focus on remediation. The Legal advisor pairs with "Ensures regulatory and legal compliance," guiding chain-of-custody, breach-notification timing, and evidence handling. The Technical lead pairs with "Coordinates forensic containment and eradication," driving the hands-on actions to isolate systems, remove the threat, and restore services.

Q10: D

D. Provisioning is correct. Provisioning is the IAM lifecycle process of creating, modifying, and revoking user accounts and access rights to systems, applications, and data. It encompasses the full lifecycle: granting access at onboarding, adjusting permissions as roles change, and removing access during offboarding (deprovisioning). A. Forensic imaging is incorrect. Forensic imaging creates a bit-for-bit copy of storage media for investigation and evidence preservation — it is an incident response activity unrelated to access management. B. Threat hunting is incorrect. Threat hunting proactively searches for hidden adversaries in the environment — it does not manage user access rights. C. Playbook execution is incorrect. Playbook execution follows predefined incident response procedures — it is not an identity or access management process.

Q11: A

B. Push-button is incorrect. The push-button (PBC) method requires physical presence and only has a short activation window, so it is not the primary WPS weakness. A. PIN is correct. The 8-digit WPS PIN is validated in two halves, effectively reducing the keyspace to about 11,000 combinations. Tools like Reaver can brute-force it in hours, allowing attackers to recover the WPA/WPA2 passphrase. D. NXC is incorrect. NXC is not a defined WPS method; it is a distractor. C. Click-to-send is incorrect. This is not a recognized WPS provisioning method.

Q12: B

D. "Scripting can integrate security tools through APIs" is a true statement, so it is not the answer; integrations and application programming interfaces (APIs) are a standard automation use case. C. "Scripting can automate user-provisioning tasks" is a true statement, so it is not the answer; user provisioning is one of the most common scripting use cases. A. "Scripting can help enforce standard infrastructure configurations and guard rails" is a true statement, so it is not the answer; automation is regularly used to apply baselines and guard rails consistently. B. "Scripting should not be used for automation" is the correct answer because the statement is false: automation is one of the primary reasons scripting is used in security operations.

Q13: C

B. Application log is incorrect because it records events generated by a specific application (errors, transactions, user actions), not information that describes other data. D. Network log is incorrect because it captures traffic and connection activity between hosts, such as source and destination addresses, not descriptions of other data. C. Metadata log is correct because metadata is "data about data" — details such as a file's creation date, size, owner, and permissions — so a metadata log records information that describes other data. A. Endpoint log is incorrect because it records activity on a specific device (processes, logins, local security events), not descriptive information about other data.

Q14: C

D. SORA is incorrect. SORA is not a recognized Security+ acronym for an application development policy and does not describe how software is built. A. SCAP is incorrect. SCAP (Security Content Automation Protocol) is a suite of specifications for standardized vulnerability and configuration reporting, not a development policy. C. SDLC is correct. The Software Development Life Cycle defines the phases, controls, and policies that govern how applications are planned, developed, tested, deployed, and maintained. B. SARC is incorrect. SARC is not a standard Security+ term for software development governance.

Q15: D

A. Weak Wi-Fi encryption is incorrect. Attacking weak wireless encryption targets the network link, not the trusted websites a victim group visits. C. USB device insertion is incorrect. That describes a removable-device or baiting vector, not the mechanism of a watering hole attack. D. Frequently visited websites is correct. In a watering hole attack, the adversary compromises a legitimate website known to be frequented by the target group, so that members are infected when they browse a site they already trust. B. Overused passwords is incorrect. Reused or weak passwords are exploited by credential attacks such as spraying or stuffing, not by a watering hole.

Q16: C

C is correct (A right-to-audit clause): a right-to-audit clause gives the customer the contractual authority to examine the vendor's controls, processes, and records, directly or through an independent assessor, so that compliance with security and regulatory obligations can be verified rather than assumed. A is incorrect (A non-disclosure agreement) because an NDA restricts how confidential information may be shared; it grants no inspection rights. B is incorrect (A statement of rules of engagement) because rules of engagement define the scope, timing, and limits of a penetration test, not ongoing audit rights over a supplier. D is incorrect (A conflict-of-interest disclosure) because it reveals relationships that could bias vendor selection; it does not give the customer any ability to inspect the vendor's environment.

Q17: A

C. Principle of least privilege is incorrect. Least privilege grants each user or process only the permissions needed for its role; it governs assigned rights, not a blanket deny-unless-allowed rule on traffic. A. Default deny is correct. A default-deny stance blocks all traffic or access unless a rule explicitly permits it, so anything not expressly allowed is rejected, exactly the behavior described. D. Zero trust is incorrect. Zero trust is a broader architecture that continuously verifies every request; default deny can be one element of it, but the specific 'deny unless explicitly allowed' rule is the default-deny principle itself. B. Role-based access is incorrect. RBAC assigns permissions based on job roles; it defines who may do what, not the deny-all-by-default posture for network traffic.

Q18: 1 = D; 2 = B; 3 = A; 4 = C

Agent-based monitoring pairs with “Requires local software installation” because an agent runs on the host itself, collecting telemetry directly from the operating system. Agentless monitoring pairs with “Uses remote access protocols without client installation,” leveraging WMI, SSH, SNMP, or APIs to gather data without deploying software. Signature-based detection pairs with “Compares observed artifacts or activity against known malicious signatures,” matching files, hashes, and traffic against a database of known indicators. Heuristic detection pairs with “Analyzes behavior to identify unknown threats,” using rules, statistical models, or behavioral analysis to flag suspicious activity that no signature yet covers.

Q19: A

C. SLA is incorrect. A service-level agreement defines measurable performance targets, such as uptime or response times, for a specific service; it is not the umbrella contract that governs the whole relationship. A. MSA is correct. A master service agreement establishes the overarching terms and conditions between the two parties, and each future project is then executed under it through its own work order or statement of work. D. MOU is incorrect. A memorandum of understanding records a mutual, often non-binding, intent to work together; it does not serve as the binding framework contract for future statements of work. B. BPA is incorrect. A business partners agreement defines each partner's responsibilities and stake in a shared business venture, not a framework for future service engagements with a vendor.

Q20: A

B. Evil twin is incorrect. An evil twin is a rogue wireless access point that impersonates a legitimate SSID to lure victims; it is a specific wireless setup, not the general act of intercepting and altering traffic between two parties. C. Session replay is incorrect. A replay attack captures valid data such as a session token and resends it later to impersonate a user; it reuses traffic rather than sitting between the parties and modifying their live communication. A. Man-in-the-middle is correct. In a man-in-the-middle (on-path) attack, the attacker secretly positions themselves between two communicating parties, relaying and potentially altering the messages while both sides believe they are talking directly to each other. D. DNS tunneling is incorrect. DNS tunneling encodes data inside DNS queries and responses to bypass controls or exfiltrate data; it is a covert channel technique, not the interception and alteration of a conversation.

Q21: 1 = C; 2 = D; 3 = B; 4 = A

HIPAA matches "Health information privacy" because it is the U.S. law protecting Protected Health Information (PHI) handled by covered entities and business associates. NIST CSF matches "Cybersecurity risk management" since the framework's five core functions (Identify, Protect, Detect, Respond, Recover) are designed to help organizations manage cyber risk systematically. PCI DSS matches "Payment security standards" as it is the industry standard that mandates controls for any entity handling cardholder data. GDPR matches "Personal data protection for EU residents" because it governs how personal data of EU data subjects must be collected, processed, stored, and disclosed.

Q22: 1 = D; 2 = C; 3 = B; 4 = A

The correct mapping is: Policy is a broad security requirement — a high-level statement of intent that defines what must be done (e.g., 'data must be protected'). Standard is a detailed technical specification that mandates specific implementations to support a policy (e.g., 'AES-256 must be used for encryption'). Guideline is recommended but not mandatory — it provides best practice advice that organizations should follow but are not required to. Procedure provides step-by-step operational instructions for carrying out a task in compliance with policies and standards. The hierarchy runs: Policy → Standard → Guideline/Procedure, each adding operational specificity.

Q23: B

B. Air-gapped isolation is correct. An air-gapped system is physically isolated, with no wired or wireless link to any other network, so data can only move to or from it through controlled physical means such as removable media. D. Logical segmentation is incorrect. Logical segmentation, for example with VLANs, separates traffic on shared infrastructure, but a physical path to other networks still exists. A. Software-defined networking (SDN) is incorrect. SDN centralizes and programs network control; it manages connectivity rather than eliminating it. C. Containerization is incorrect. Containerization isolates applications on a shared operating system; the host itself remains connected to the network.

Q24: A

A. Correct — automated ticket creation and routing on a critical scanner finding is a recognized automation use case: it speeds escalation and ensures critical vulnerabilities are tracked without manual delay. B. Automatically granting every new user administrator privileges is incorrect because it violates least privilege; automated user provisioning should assign only the access each role requires. C. Automatically disabling endpoint logging under storage pressure is incorrect because it would blind monitoring and investigations exactly when data is needed; storage issues call for expansion or archiving instead. D. Automatically deleting unreviewed security alerts is incorrect because it can silently discard evidence of unresolved threats; alerts should be triaged or tuned, not purged unseen.

Q25: 1 = F; 2 = G; 3 = E; 4 = A; 5 = D

1 → F (Hashing): hashing produces a fixed-length, one-way digest used to verify that data has not changed. 2 → G (Salting): salting adds random data to a password before hashing so precomputed rainbow tables do not work. 3 → E (Steganography): steganography conceals the very existence of a message by hiding it inside another file. 4 → A (Tokenization): tokenization swaps sensitive data for a non-sensitive token while the original is held in a secure vault. 5 → D (Digital signature): a digital signature applies the sender's private key to prove origin and integrity. Unused: C (full-disk encryption) — volume encryption is not one of these techniques; B (chain of trust) — distributing CA trust describes PKI structure, not a listed technique.

Q26: B

D. CRL is incorrect. A Certificate Revocation List is a static, periodically published list of revoked certificates. Clients must download the entire list and it may be outdated between publication cycles. C. LDAP is incorrect. LDAP (Lightweight Directory Access Protocol) is used for directory lookups to retrieve user and resource information — not for checking certificate revocation status. A. RADIUS is incorrect. RADIUS (Remote Authentication Dial-In User Service) handles centralized authentication for network access and is unrelated to PKI certificate status queries. B. OCSP is correct. OCSP (Online Certificate Status Protocol) allows a client to query a CA's OCSP responder in real time for the status of a specific certificate. Unlike CRL, OCSP returns a targeted response for just the queried certificate, making it more timely and bandwidth-efficient.

Q27: C

B. Host-based firewall is incorrect. A host-based firewall filters network traffic to and from a device; it cannot stop a person from being deceived into revealing information or taking an unsafe action. C. User training and awareness is correct. Social engineering targets human judgment, so educating users to recognize and report phishing, pretexting, and similar manipulation is the most effective countermeasure. A. NAT is incorrect. Network Address Translation remaps IP addresses and offers no defense against manipulation of people. D. Data loss prevention (DLP) is incorrect. DLP can help limit what leaves the organization, but it does not prevent a user from being tricked in the first place.

Q28: 1 = B; 2 = A; 3 = C; 4 = F

1 → B (A firewall access list applies the same permit and deny conditions to every connection attempt, whoever initiates it): rule-based access control enforces predefined conditions uniformly, without regard to the individual identity behind the request. 2 → A (Contractor accounts are prevented from signing in between 8 p.m. and 6 a.m.): a time-of-day restriction limits when an account may be used, shrinking the window in which stolen credentials are useful. 3 → C (Managers formally certify each quarter that the people on their team still require the access they hold): attestation is the periodic, documented confirmation of entitlements that catches privilege creep. 4 → F (A new hire must present a government-issued ID and answer knowledge-based verification questions before an account is created): identity proofing verifies that a person is who they claim to be before an identity is issued. Unused: D (Access is recalculated at every request from the requester's department, device posture, and clearance) — that is attribute-based access control, which weighs identity attributes rather than applying one fixed rule to everyone; E (Every user receives only the permissions required to perform their job duties) — that is least privilege, a principle that guides how rights are sized rather than a control applied in one of these situations.

Q29: A

A. An automated assessment that identifies known weaknesses in systems or applications is correct: a vulnerability scan runs automated tools against hosts and software and compares the results with databases of known vulnerabilities. D. An audit that evaluates only security procedures and processes is incorrect because that describes a system/process audit, which is a separate identification method in vulnerability management. B. A guarantee that every reported weakness is exploitable is incorrect because scan output can contain false positives that must be confirmed during analysis. C. A one-time activity that removes the need to rescan is incorrect because rescanning after remediation is the standard way to validate that fixes actually worked.

Q30: 1 = B; 2 = C; 3 = A; 4 = D

Federation pairs with "Linking identities across organizations" because federated identity uses standards like SAML or OIDC to let users authenticate in one domain and access resources in another. SSO pairs with "Centralized authentication across services" since a user logs in once and gains access to multiple internal systems without re-authenticating each time. MFA pairs with "Using multiple verification methods," combining factors such as something you know, have, and are to raise assurance. Deprovisioning pairs with "Automatically removing access when no longer needed," ensuring that accounts are disabled and entitlements revoked promptly at offboarding or role change.

Q31: D

B. Disabling file sharing is incorrect. It removes one specific service but does not stop network-based lateral movement between workloads over other protocols and paths. D. Microsegmentation is correct. It divides the network into small, isolated zones with per-workload security policies, so a compromised account can reach far fewer systems and lateral movement is contained. A. Application whitelisting is incorrect. It restricts which executables can run on a host; it does not constrain network paths between workloads. C. VLAN hopping is incorrect. It is an attack technique that escapes VLAN boundaries, not a security control.

Q32: B

B (Guardrails add friction to slow down the development process.) is correct: the question asks for the statement that is NOT true, and this one is false. Cloud guardrails are automated policy controls that let developers move quickly while staying within safe boundaries; they reduce friction rather than add it, catching misconfigurations without manual reviews. C (Guardrails can automatically remediate issues.) is incorrect as an answer because guardrails can be configured to fix a violation automatically. D (Guardrails constantly watch cloud deployments.) is incorrect as an answer because continuous monitoring of the cloud environment is a defining characteristic of guardrails. A (Guardrails leverage cloud APIs and automation.) is incorrect as an answer because guardrails work precisely by using the provider's APIs and automation to enforce policy at scale.

Q33: 1 = A; 2 = D; 3 = C; 4 = B

The correct pairings are: SLA = Defines expected performance and services; NDA = Legal protection of shared confidential data; AUP = Outlines acceptable behavior when using systems; MOU = High-level understanding between two parties. An SLA (Service Level Agreement) specifies measurable performance targets such as uptime, response times, and support windows. An NDA (Non-Disclosure Agreement) is a legal contract preventing parties from disclosing confidential information. An AUP (Acceptable Use Policy) sets rules for employees about appropriate use of IT resources. An MOU (Memorandum of Understanding) is a non-binding document that establishes a general framework of cooperation between organizations.

Q34: C, D

C and D are correct: the policy engine evaluates context and makes the access decision, and the policy administrator carries that decision out by managing session credentials, so both are control-plane functions. E is incorrect: the policy enforcement point is a data-plane component that actually permits or blocks traffic. A is incorrect: an implicit trust zone exists in the data plane and describes an area trusted after a request passes the PEP. B is incorrect: the subject or system is the requesting entity in the data plane, not a decision-making component.

Q35: B

A. Threat hunting driven by hypotheses about adversary behavior is incorrect. Threat hunting is the proactive human-led search for undetected adversaries; it consumes aggregated data but is not the platform that collects and correlates logs. C. Incident triage against a documented severity matrix is incorrect. Triage prioritizes alerts once they exist; it is a response activity, not the technology that collects and correlates logs from multiple devices. B. SIEM (Security Information and Event Management) is correct. A SIEM ingests logs and events from many devices, normalizes them, and correlates them into a single view, enabling alerting and investigation across the environment. D. Log analysis performed on a single host's local records is incorrect. Examining one system's logs in isolation gives no cross-device correlation; the question asks for the platform that groups and correlates logs from multiple sources, which is the SIEM.

Q36: 1 = B; 2 = A; 3 = C; 4 = D

The correct pairings are: Risk appetite = General level of risk an organization is willing to accept; Residual risk = Level of risk remaining after controls; Risk tolerance = Willingness to accept deviations within limits; Inherent risk = Total risk without controls applied. Risk appetite is the high-level strategic statement of how much risk leadership accepts in pursuit of objectives. Inherent risk is the raw level of risk present before any controls are applied. Residual risk is what remains after controls have been implemented — even well-protected environments retain some residual risk. Risk tolerance is narrower than appetite — it defines the acceptable variance from the target risk level in operational terms, specifying how much deviation from appetite is permissible.

Q37: A

B. Zero-day escalation is incorrect. This scenario chains known low-severity bugs; it does not hinge on a previously unknown (zero-day) vulnerability. C. Privilege elevation is incorrect. Privilege elevation/escalation names the outcome (gaining admin rights), not the technique of combining several weaknesses to get there. D. Vulnerability stacking is incorrect. This is not an established term for the technique described. A. Exploit chaining is correct. Exploit chaining links multiple individually minor vulnerabilities together so that their combined effect achieves a high-impact result such as administrative access.

Q38: C

A. Cloud monitoring is incorrect. Cloud monitoring observes resource health and metrics; it does not define or enforce server configurations. D. Asset tagging is incorrect. Tags identify and categorize assets for tracking and billing but do not drive configuration uniformity. C. Configuration baselines is correct. A baseline defines the approved, standardized configuration for systems, and automated tooling compares running systems against that baseline to detect drift and enforce consistency. B. Virtual patching is incorrect. Virtual patching uses network-layer filters to block exploitation of a vulnerability without changing the system itself; it does not standardize configurations.

Q39: B

A. DNS spoofing is incorrect. DNS spoofing corrupts name-resolution responses to redirect victims to malicious hosts; it does not guess passwords. B. Brute-force attack is correct. A brute-force attack uses automation to try large numbers of password guesses in rapid succession until the correct one is found; account lockouts, rate limiting, and MFA are common defenses. D. Clickjacking is incorrect. Clickjacking tricks a user into clicking a hidden or disguised UI element; it targets user interaction, not password guessing. C. Man-in-the-middle is incorrect. A man-in-the-middle attack intercepts or alters traffic between two parties; it captures or manipulates data in transit rather than iterating through password guesses.

Q40: B

C. To replace an organization's cloud-delivered security services is incorrect. A UTM is an on-network appliance; it is not defined by replacing cloud-delivered security, and many organizations run both. B. To combine multiple security functions in one device is correct. Unified Threat Management consolidates capabilities such as firewall, IDS/IPS, antivirus, content/URL filtering, and VPN into a single appliance for simpler management. D. To store and protect the organization's encryption keys is incorrect. Secure key storage and protection is the role of an HSM or key management system, not a UTM. A. To manage multifactor authentication enrollment and tokens is incorrect. Enrolling users and issuing MFA tokens is handled by identity and access management systems, not by a UTM appliance.

Q41: D

C. Encrypting secure email is a genuine use: the public key bound in a certificate is used to protect email messages. A. Encrypting channels is a genuine use: TLS relies on server certificates to establish secure sessions between clients and servers. D. This is the correct answer: no digital certificate can guarantee that a certificate authority will never be compromised — certificates express trust relationships, they do not provide immunity from CA compromise. B. Verifying the identity of clients and servers on the web is a genuine use and the core purpose of TLS certificates.

Q42: D

D is correct ($25,000): single loss expectancy (SLE) is asset value multiplied by exposure factor, so $200,000 × 0.25 = $50,000 per fire. The annualized rate of occurrence (ARO) for an event expected once every two years is 0.5, and ALE = SLE × ARO = $50,000 × 0.5 = $25,000. This is the figure used to judge whether a countermeasure's yearly cost is justified. C is incorrect ($12,500) because it applies the ARO twice, halving the correct ALE. B is incorrect ($50,000) because it is the SLE, the loss from a single fire, and ignores that the fire is expected only every other year. A is incorrect ($100,000) because it multiplies the SLE by 2 as if the fire happened twice a year, instead of using an ARO of 0.5.

Q43: D

D (SIEM platforms) is correct: continuous monitoring depends on collecting logs from across the whole estate, correlating them and alerting around the clock, which is exactly the role a SIEM plays at the centre of a SOC. C (Data backup tools) is incorrect because backups support recovery and availability and give no ongoing visibility into security events. B (Packet sniffers) is incorrect because a sniffer offers a deep but point-in-time view of one segment and lacks the correlation, retention and alerting a SOC needs. A (Email gateways) is incorrect because they filter a single channel and feed a SIEM rather than replacing it.

Q44: B

B is correct (Backout plan): a backout, or rollback, plan defines how to restore the prior working configuration if a change causes problems. C is incorrect (Impact analysis): impact analysis evaluates the technical and business consequences of a change before approval, not how to undo it. A is incorrect (Maintenance window): a maintenance window is the scheduled time to perform the change, not the recovery procedure. D is incorrect (Standard operating procedure): an SOP is a repeatable step-by-step guide for a task, not the specific rollback for a failed change.

Q45: D

C. Social engineering is incorrect. Social engineering is an attack category involving human manipulation — it is not a CVSS metric. B. SQL injection is incorrect. SQL injection is an attack technique, not a component of CVSS vulnerability scoring. D. Exploitability is correct. The CVSS Exploitability metrics measure how easily a vulnerability can be exploited — incorporating factors such as attack vector (network vs. local), attack complexity, privileges required, and user interaction needed. Higher exploitability scores indicate lower barriers to exploitation. A. Buffer overflow is incorrect. A buffer overflow is a specific vulnerability type, not a CVSS scoring metric.

Q46: C

A. Vulnerability scanning is incorrect. Vulnerability scanning is a separate proactive process performed before an incident, not a phase within the incident response lifecycle. C. Identification is correct. The Identification phase (also called Detection and Analysis) focuses on determining whether a security event has actually occurred — analysts review alerts, logs, and indicators of compromise to confirm and classify the incident before moving to containment. B. EDR containment is incorrect. Containment is a later phase in incident response that occurs after an incident has been identified and confirmed. D. Log analysis is incorrect. Log analysis is a tool or activity used during identification, not the name of the phase itself.

Q47: C

C. Type I is correct because a Type I (bare-metal) hypervisor runs directly on the host's physical hardware and manages the guest operating systems itself. A. Type II is incorrect because a Type II (hosted) hypervisor runs as an application on top of an existing operating system rather than directly on the hardware. D. Type III is incorrect because there is no Type III hypervisor classification. B. Type IV is incorrect because there is no Type IV hypervisor classification.

Q48: C

B. Rootkit is incorrect. A rootkit is malware that conceals its presence and grants persistent admin access — it would not selectively stop update processes in response to a configuration change. C. Misconfiguration is correct. When multiple systems simultaneously stop receiving updates after a configuration change, the most logical cause is a misconfiguration — such as an incorrect update server URL, a firewall rule blocking update traffic, or a group policy error — rather than a security attack. D. Session hijacking is incorrect. Session hijacking targets active user sessions in applications — it does not cause systems to stop receiving software updates. A. Policy violation is incorrect. A policy violation describes non-compliant human behavior, not a technical failure mode causing update delivery to break.

Q49: A

A (Network traffic analyzer) is correct: lateral movement is the attacker's technique of moving from the initially compromised host to other systems inside the network, and that movement leaves traces in network traffic such as unusual SMB, RDP, or authentication connections between internal hosts. A network traffic analyzer lets investigators reconstruct which systems the attacker reached and when. D (Patch manager) is incorrect because patch management deploys updates to reduce vulnerabilities; it does not record attacker activity. C (Backup client) is incorrect because backup software copies and restores data; it provides no visibility into host-to-host connections during a breach. B (Secure email gateway) is incorrect because an email gateway filters messages and could show the initial phishing delivery, but it cannot trace movement between internal systems.

Q50: D

C. Whitelisting is incorrect: application allow-listing controls which programs may run, it does not itself close unused ports and services. B. Sandboxing is incorrect: it isolates code execution for containment, not for reducing exposed services. D. System hardening is correct: hardening reduces the attack surface by disabling unnecessary ports, services, and accounts and applying secure configuration. A. Load balancing is incorrect: it distributes traffic across servers for availability, not for reducing the attack surface.

Q51: C

A. Honeyfile is incorrect. A honeyfile is a decoy file, such as a fake passwords.txt, placed to lure attackers into opening it; it is a file to be accessed, not a credential or record designed to be used. B. Honeypot is incorrect. A honeypot is an entire decoy system set up to attract attackers and observe their techniques. D. Honeynet is incorrect. A honeynet is a network of honeypots that simulates a complete environment. C. Honeytoken is correct. A honeytoken is a fake data item such as a bogus credential, API key, or database record; because it has no legitimate use, any use of it is a reliable indicator of unauthorized access.

Q52: B

D. To enable geofencing for location-based access is incorrect. Geofencing uses GPS, Wi-Fi, or IP location data to enforce location-based policy - it has no relationship to certificate self-signing. C. To bypass HTTPS certificate warnings shown by browsers is incorrect, and in fact reversed. A self-signed certificate is what causes the browser warning, because it is not issued by a publicly trusted CA; it does not suppress warnings or bypass the protocol. B. To encrypt and authenticate internal communications is correct. A self-signed certificate lets an organization secure internal services (dev environments, internal APIs, internal admin consoles) with TLS without purchasing a public CA-signed certificate. It provides encryption and, if the issuer is trusted by internal systems, authentication - at the cost of not being trusted by external parties. A. To sign authoritative DNS responses for a public zone is incorrect. DNS responses are signed with DNSSEC zone-signing and key-signing keys, not with TLS certificates; the two systems are separate.

Q53: B

A. Availability is incorrect. Availability ensures systems and data are accessible when needed; encryption does not primarily serve that goal and can even add overhead. D. Accountability is incorrect. Accountability ties actions to identities through logging and auditing, and it is not one of the three CIA elements that encryption supports. B. Confidentiality is correct. Encrypting data at rest and in transit keeps it unreadable to unauthorized parties, which is the essence of confidentiality. C. Integrity is incorrect. Integrity ensures data is not altered and is verified mainly with hashing and digital signatures; encryption alone protects secrecy rather than detecting modification.

Q54: 1 = C; 2 = A; 3 = D; 4 = B

Tailgating pairs with "Following someone into a secured area" because the attacker physically slips in behind an authorized person through a controlled door. Pretexting pairs with "Lying about identity to obtain data" since the attacker fabricates a believable scenario or false identity to manipulate the target. Vishing pairs with "Fake phone call from technical support" because it is voice-based phishing carried out over the telephone, often impersonating IT or help desk staff. Baiting pairs with "Leaving infected USB drives" because it relies on enticing the victim with attractive physical media that, when plugged in, delivers malware.

Q55: C

D. Detective is incorrect. A detective control (like IDS alerts or log reviews) identifies incidents after the fact rather than blocking them. C. Preventive is correct. Automatically blocking known-malicious IPs stops attacks before they can impact systems, which is the defining purpose of a preventive control. B. Corrective is incorrect. Corrective controls act after an incident to restore systems or mitigate damage (e.g., restoring from backup). A. Compensating is incorrect. Compensating controls substitute for a primary control that cannot be implemented; IP blocklisting is itself a primary preventive measure.

Q56: A

A (Provides controlled access to a private network from an external location) is correct: a bastion host, or jump server, is a hardened and closely monitored system on the untrusted edge that administrators must pass through, giving one auditable entry point into internal systems. C (Distributes inbound client sessions evenly across a pool of backend servers) is incorrect because spreading sessions across a server pool for performance and availability is the job of a load balancer. B (Hosts a DMZ for client VPN connections) is incorrect because terminating client VPNs belongs to a VPN concentrator or firewall; a bastion may sit inside a DMZ but does not host one. D (Monitors container orchestration in cloud) is incorrect because that is the work of cloud workload protection and posture management tooling.

Q57: C

C. Traffic analysis is correct. It examines flow-level patterns — connection timing, frequency, volume, and destinations — across the network, which is exactly how periodic outbound beaconing to a C&C server is identified. B. Port analysis is incorrect. Examining which ports and services are open or in use does not reveal the temporal pattern of repeated outbound connections. D. Packet analysis is incorrect. Inspecting the contents of individual packets can support a deeper investigation, but it does not aggregate timing and frequency patterns across connections, which is what exposes beaconing. A. Probe analysis is incorrect. Probing refers to actively scanning systems for information; it is not a method for reviewing outbound communication patterns.

Q58: D

C. Automatically restore backup data after a system outage is incorrect. Automated backup restoration is a disaster-recovery capability; a BCP is broader and is not limited to restoring data. B. Detect insider threats through continuous behavior monitoring is incorrect. Detecting malicious insiders is a monitoring and user-behavior-analytics function, not the purpose of a continuity plan. D. Maintain operations during and after disruptions is correct. A business continuity plan defines how an organization keeps its essential functions running during and after an incident or disaster, minimizing downtime to critical operations. A. Enforce perimeter firewall rules across all network edges is incorrect. Enforcing firewall rules is a preventive network-security control and has nothing to do with sustaining business operations through a disruption.

Q59: A

D. Local-only authentication is incorrect. Restricting authentication to a local source does not deliver the continuous, context-aware verification zero trust demands. C. Role-based access without reauth is incorrect. Granting access by role and then not re-verifying assumes standing trust, which contradicts zero trust's 'never trust, always verify' principle. B. Always-on VPN is incorrect. A VPN establishes an encrypted tunnel and often implies broad implicit trust once connected, the opposite of evaluating each request individually. A. Per-request policy evaluation is correct. Zero trust evaluates identity, device posture, and context on every request rather than trusting a session after initial login, so per-request policy evaluation directly embodies the model.

Q60: C

A. This statement is true: threat intelligence is precisely data collected, processed, and analyzed to understand threat actors' motives, targets, and attack behaviors, so it is not the correct choice. B. This statement is true: by providing evidence-based context, threat intelligence enables faster, more informed security decisions, so it is not the correct choice. C. Correct — this statement is NOT true: threat intelligence is an analytical product built from threat feeds and other intelligence sources; it does not involve actively exploiting target systems, which describes penetration testing instead. D. This statement is true: knowing threat actors' tactics in advance shifts an organization from reacting to incidents toward proactively defending against anticipated attacks, so it is not the correct choice.

Q61: B

A. 'A threat is an unpatched system; a vulnerability is an attacker' is incorrect. The definitions are reversed: an unpatched system is a vulnerability, and an attacker is a threat actor. B. 'A vulnerability is an exploitable weakness; a threat is a potential cause of harm' is correct. A vulnerability is a weakness that could be exploited, whereas a threat is any potential event or actor that could exploit a vulnerability to cause harm. C. 'A vulnerability is detected after a threat; a threat is the result' is incorrect. Vulnerabilities exist independently of, and typically before, any threat acting on them; a threat is not the 'result.' D. 'They are interchangeable terms' is incorrect. Vulnerability and threat are distinct concepts and are not synonyms.

Q62: B, D

D and B are correct: nation-state actors are backed by government-level funding and field advanced capabilities such as custom malware and zero-day exploits. A is incorrect: relying only on pre-built tools without understanding them describes an unskilled attacker, not a nation-state. E is incorrect: petty vandalism for fun characterizes low-skill actors, whereas nation-states pursue espionage, sabotage, or strategic advantage. C is incorrect: nation-state operations are typically stealthy and hard to attribute, not consistently noisy.

Q63: C

A. Rogue portal is incorrect. A rogue portal is a malicious portal designed to steal credentials — it masquerades as a legitimate login page and is associated with evil twin attacks, not legitimate coffee shop Wi-Fi. B. Approval portal is incorrect. This is not a standard term in networking or security; there is no recognized portal type by this name. D. Limited portal is incorrect. This is also not a standard classification for wireless access portals. C. Captive portal is correct. A captive portal intercepts the user's first HTTP request and redirects them to a web page requiring acceptance of an AUP or providing credentials before granting full network access. Public Wi-Fi in hotels, cafes, and airports commonly uses this mechanism.

Q64: A

A (Security awareness training) is correct: administrative, or managerial, controls are the policies, procedures and training that govern how people behave, and awareness training is the textbook example, cutting susceptibility to phishing and everyday human error. C (SIEM alerting) is incorrect because log correlation and alerting is implemented in software and is therefore a technical control. D (Patch management scripts) is incorrect because automated patching is likewise technical, enforced by the system rather than by written policy. B (Motion detector) is incorrect because a sensor guarding a physical space is a physical control.

Q65: D

D. Change in ownership or stakeholders is correct: it is an organizational change that alters who is accountable for or affected by a system, not an activity executed as part of a change procedure. C. Implementing impact analysis or test results is incorrect: these are procedural change-management activities used to evaluate and validate a change. B. Executing a backout plan or using a maintenance window is incorrect: both are procedural mechanisms for deploying a change safely and reversing it if needed. A. Changing allow lists/deny lists is incorrect: it is a technical, procedural activity performed while implementing a change.

Q66: 1 = B; 2 = C; 3 = D; 4 = A

Vishing matches the automated phone call because vishing uses voice calls to trick victims into revealing account credentials. Smishing matches the SMS about the locked bank account because smishing delivers phishing lures over text messages. Pretexting matches the fabricated external-auditor identity because pretexting builds an invented persona and backstory to gain trust and extract confidential information. Business email compromise matches the apparent CEO email because BEC impersonates a trusted executive identity to induce a fraudulent payment.

Q67: A

A. Correct — this statement is false: business email compromise (BEC) has been growing in popularity among threat actors because it is effective and can yield large payouts, so calling it 'decreasing' is inaccurate. B. BEC does exploit electronic payments and funds transfers, so this statement is true and not the answer. C. BEC does take advantage of the size and complexity of large enterprises, where requests are harder to verify, so this statement is true and not the answer. D. BEC is not limited to businesses; individuals and other organizations can also be targeted, so this statement is true and not the answer.

Q68: D

D (It separates personal data from corporate data.) is correct: containerization creates an encrypted area for corporate apps and data that is managed separately from the user's personal apps. This is what makes BYOD and COPE deployments workable because the corporate container can be secured or wiped without touching personal content. A (It splits operating system functions only on specific brands of mobile devices.) is incorrect because containerization is not brand specific and it isolates data and applications rather than dividing operating system functions. C (It places all keys in a special vault.) is incorrect because secure key storage is handled by hardware features such as a secure enclave or TPM, not by containerization. B (It slows down a mobile device to half speed.) is incorrect because containerization is a logical separation with no such performance effect.

Q69: 1 = D; 2 = A; 3 = B; 4 = C

SY0-701 groups security controls into four categories. Technical controls are implemented through technology - anti-malware software. Managerial controls govern through policy and oversight - the security policy document. Operational controls are carried out by people in day-to-day activities - incident response training. Physical controls protect the physical environment - the camera system.

Q70: B

C. Federation is incorrect. Federation lets a user authenticate once with one identity provider and access resources across separate organizations or domains; it does not describe combining multiple credentials at a single login. A. Two-step verification is incorrect. Two-step verification adds a second step that may rely on the same factor category (for example, a password followed by an emailed code); this scenario deliberately combines two different factor categories. B. Multifactor authentication is correct. The login combines something you know (the password) with something you are (the fingerprint) - two distinct authentication factors - which is the defining characteristic of multifactor authentication. The username is only an identifier, not a factor. D. Single sign-on is incorrect. Single sign-on lets one authenticated session grant access to many applications without re-authenticating; it does not refer to using multiple factors.

Q71: C

C. DNS spoofing is correct: forging or modifying DNS responses so that a legitimate name resolves to an attacker-controlled address redirects users to a malicious site. A. VLAN hopping is incorrect because it abuses switch/VLAN tagging behavior to reach other network segments; it does not manipulate name resolution. B. Session hijacking is incorrect because it takes over an existing authenticated session rather than altering DNS answers. D. Password spraying is incorrect because it tries a few common passwords across many accounts and involves no DNS manipulation.

Q72: A

C. Lower email deliverability is incorrect: it is a messaging/reputation issue, not a consequence of weak cryptography. B. Failure of biometric devices is incorrect: biometric hardware is unrelated to the strength of a communication cipher. A. Exposure to brute-force or known attacks is correct: outdated algorithms (e.g., DES, MD5) have known weaknesses and short key lengths, making them susceptible to brute-force and published cryptanalytic attacks. D. Increase in memory usage is incorrect: outdated algorithms are often less resource-intensive, and memory is not the security risk here.

Q73: B

B. Risk assessment is correct. Risk assessment is the systematic process of identifying, analyzing, and evaluating risks — assigning likelihood and impact scores to prioritize which risks require treatment and in what order. It forms the foundation of any risk management program. A. Security awareness training is incorrect. Training educates employees to recognize threats but does not itself evaluate or rank organizational risks. C. Third-party audit is incorrect. A third-party audit verifies compliance with standards or regulations — it is an evaluation of controls, not a risk ranking methodology. D. Policy review is incorrect. Policy review examines whether documented rules are current and effective — it is not the process of evaluating and ranking risks by likelihood and impact.

Q74: A

D. SIEM is incorrect. A SIEM aggregates, correlates, and alerts on security events; it is not primarily a playbook-driven orchestration engine for response workflows. A. SOAR is correct. Security orchestration, automation, and response platforms connect multiple security tools and run playbooks that automate workflows such as ticket creation, escalation, and disabling access. B. Vulnerability scanner is incorrect. It identifies weaknesses in systems and applications; it does not orchestrate response actions across tools. C. DLP is incorrect. Data loss prevention monitors and controls the movement of sensitive data; it does not run cross-tool response playbooks.

Q75: A

A (Threat hunting) is correct: threat hunting is the proactive, hypothesis-driven search for malicious activity that has already slipped past existing defenses without triggering an alert. Analysts query SIEM data, endpoint telemetry, and threat intelligence to find hidden adversaries. C (Vulnerability scanning) is incorrect because scanning identifies weaknesses such as missing patches and misconfigurations; it looks for exposures, not for attackers already inside. D (Penetration testing) is incorrect because a pentest is an authorized simulated attack that tests whether defenses can be breached, rather than a search for real intruders who evaded them. B (Log analysis) is incorrect because reviewing logs is a technique that threat hunters use, but by itself it is general monitoring and not the proactive process the blank describes.

Q76: 1 = A; 2 = D; 3 = C; 4 = B

Kerberos matches "Ticket-granting protocol for internal SSO" because it uses a Key Distribution Center to issue time-limited tickets that authenticate users across services within an Active Directory domain. RADIUS matches "Used for centralized authentication over UDP," providing AAA services for network access (VPN, 802.1X, remote access) via UDP ports 1812/1813. LDAP matches "Directory access protocol used for user lookups," supplying read and write access to directory entries such as users, groups, and computers. SAML matches "Federated identity for cloud-based applications" since it is an XML-based standard that exchanges authentication assertions between identity providers and service providers in web SSO scenarios.

Q77: D

B. NAT is incorrect. Network address translation maps private IP addresses to public ones at a network boundary; it is an addressing function, not a bundled security platform. D. UTM is correct. Unified threat management appliances are defined precisely by combining multiple security functions — firewall, antivirus, intrusion detection or prevention, and content filtering — within a single platform. C. WAF is incorrect. A web application firewall specializes in inspecting HTTP/HTTPS traffic to protect web applications; it does not bundle antivirus and content filtering for the whole network. A. NGFW is incorrect. A next-generation firewall adds application awareness and intrusion prevention to firewalling, but the category defined by bundling firewall, antivirus, IDS/IPS, and content filtering in one appliance is the UTM.

Q78: A

A. Correct — this statement is NOT true: a secure cookie protects the cookie itself during transmission; it does not protect the web browser from malware or other browser attacks. B. The Secure attribute does instruct the browser to send the cookie only over a secure (HTTPS) connection, so this statement is true and not the answer. C. When HTTPS is used, TLS encrypts the HTTP request, including the header that carries the cookie, so this statement is true and not the answer. D. Because the cookie travels inside an encrypted channel, an interceptor who captures the traffic cannot read the cookie's contents in transit, so this statement is true and not the answer.

Q79: A

D. RTO is incorrect. The Recovery Time Objective sets the maximum acceptable time to restore a service after a disruption; it measures downtime, not the point in time to which data is recovered. A. RPO (Recovery Point Objective) is correct. The RPO defines the maximum acceptable amount of data loss expressed as a point in time, the moment to which data must be restored, and therefore drives how frequently backups or replication must run. C. MTBF is incorrect. Mean Time Between Failures is a reliability metric describing how long a component operates before failing; it says nothing about data restore points. B. SLA is incorrect. A Service Level Agreement is a contract defining expected service levels; it may reference RPO/RTO but is not itself the data-restore-point metric.

Q80: D

B. RPO is incorrect. Recovery Point Objective defines the maximum acceptable data loss measured in time, not an incident response phase. A. MTBF is incorrect. Mean Time Between Failures is a reliability metric for hardware, not an IR phase. C. MTTR is incorrect. Mean Time To Repair measures average time needed to fix failures; it is a maintenance metric, not an IR phase. D. Recovery is correct. In the NIST incident response lifecycle, the Recovery phase restores affected systems to normal operations, verifies they function properly, and returns them to production after eradication.

Q81: A

B. Conflict-based resource race condition is incorrect because it is not a standard classification of race conditions. D. Value-comparison memory race condition is incorrect because it is likewise not a recognized category. C. Thread-scheduling execution race condition in the kernel scheduler is incorrect because it is a generic label for concurrent execution rather than a recognized named pattern, and the scheduler is not what changes the reference here; the scenario hinges on a validated state changing between validation and use. A. Time-of-check/time-of-use (TOCTOU) race condition is correct because the application checked that the reference was valid and, before it was used, another process changed it - that gap between the time of check and the time of use is exactly what defines a time-of-check to time-of-use race condition, and here it results in a NULL pointer dereference.

Q82: A

A. Authentication is correct. Authentication is a security control used to verify an identity; it is something implemented on the system, not a resource or design consideration that constrains it. D. Cost is incorrect. Cost is an architecture consideration: tight budgets limit the hardware and the security capabilities an embedded system can include. C. Power is incorrect. Power is an architecture consideration: embedded devices often run on limited power, which restricts the processing available for security functions. B. Compute is incorrect. Compute is an architecture consideration: constrained CPU and memory limit the cryptography and monitoring an embedded system can support.

Q83: A

C. XSS is incorrect: cross-site scripting injects client-side scripts into web pages viewed by other users, not into SQL statements. B. Directory traversal is incorrect: it manipulates file paths to access files outside the intended directory, not database queries. A. SQL injection is correct: inserting malicious input into a dynamically built SQL statement lets an attacker alter the query to read or modify database data. D. XML external entity is incorrect: XXE abuses XML parsers to disclose files or reach internal services, it does not target SQL statements.

Q84: A

A is correct (Attestation): attestation is a formal declaration by a responsible party that specific statements about controls are accurate. It converts the results of a review into an accountable, signed assertion that customers and auditors can rely on. D is incorrect (Self-assessment) because the self-assessment is the internal review the vendor performed to gather the evidence; the signed statement built on it is the attestation. B is incorrect (Regulatory examination) because an examination is conducted by a government or industry regulator with legal authority, not by the company's own executives. C is incorrect (Independent third-party audit) because in a third-party audit an external firm tests the controls and issues its own opinion; here the vendor is asserting the results itself.

Q85: A

C. Data encryption is incorrect. Encryption protects data confidentiality in transit or at rest but does nothing to verify that a state-changing request was intentionally issued by the user, which is what CSRF abuses. A. Token-based session validation is correct. An unpredictable anti-CSRF token tied to the user's session must accompany each state-changing request; because a malicious cross-site page cannot read or guess this token, the forged request is rejected. D. Strong passwords are incorrect. CSRF rides on an already-authenticated session, so password strength is irrelevant — the victim is already logged in. B. DNS filtering is incorrect. DNS filtering blocks resolution of malicious domains; it does not validate the origin or intent of requests sent to a legitimate application.

Q86: B

A. Documented recovery procedures is a true element, so it is not the correct choice: a BCP must document how critical operations are restored and continued during a disruption. B. Simplicity as a mandatory planning objective is the correct answer because it is NOT a required BCP element: simplicity is a desirable quality, but continuity plans often must be detailed and comprehensive to cover multiple disruption scenarios. C. Defined recovery roles and responsibilities is a true element, so it is not the correct choice: a BCP must state who performs each recovery task and who has decision authority. D. Prioritized critical business functions is a true element, so it is not the correct choice: identifying and prioritizing critical functions, typically from the business impact analysis, is the foundation of the plan.

Q87: B

A. Hashing is incorrect. Hashing transforms data into a fixed-length digest and is irreversible — it does not use a key and cannot be decrypted. D. Tokenization is incorrect. Tokenization replaces sensitive data with a non-sensitive placeholder (token) but does not use an algorithm and key to transform plaintext to ciphertext. B. Encryption is correct. Encryption uses a public or shared algorithm combined with a key to convert plaintext into ciphertext, which can be reversed with the appropriate key. C. Obfuscation is incorrect. Obfuscation makes data harder to understand but does not follow a formal algorithm-and-key model to produce ciphertext.

Q88: 1 = D; 2 = C; 3 = A; 4 = B

The correct mapping is: MAC (Mandatory Access Control) is based on labels and classification levels — the system enforces access based on data sensitivity labels (e.g., Confidential, Secret) and user clearance levels, with no discretion granted to data owners. RBAC (Role-Based Access Control) is based on roles and job functions — users inherit permissions from their assigned role (e.g., 'Network Admin' role), simplifying management in large organizations. ABAC (Attribute-Based Access Control) is based on rules and multiple attributes — decisions incorporate user department, time of day, device type, location, and other contextual factors. DAC (Discretionary Access Control) is based on user-defined permissions — resource owners decide who can access their files or objects.

Q89: 1 = C; 2 = B; 3 = D; 4 = A

The Legal advisor pairs with "Ensures chain of custody and compliance" because this role oversees evidence handling, breach notification obligations, and regulatory adherence. The Technical lead pairs with "Directs technical remediation and containment," driving the hands-on isolation of systems and removal of threats. The Communications officer pairs with "Handles external and internal messaging," managing press statements, customer advisories, and employee updates. The Incident commander pairs with "Leads response activities and decision-making," having overall authority to coordinate resources, approve actions, and escalate across the response team.

Q90: B

D. Force Allow is incorrect because it is vendor-specific terminology, not a standard firewall rule action. A. Force Deny is incorrect for the same reason, and it would block rather than permit matching traffic. C. Bypass is incorrect because it skips rule inspection entirely instead of permitting an explicitly configured exception. B. Allow is correct: under a default-deny policy, an Allow rule is the standard action that permits traffic matching an explicit exception, while all unmatched traffic remains denied by the default policy.